ADscan | CLIENT DELIVERABLE KIT

ACTIVE DIRECTORY HARDENING PLAYBOOK

Your *30-day* path from findings to a hardened domain.

Built from the 22 findings ADscan confirmed against essos.local, sequenced into shippable work and mapped to the compliance controls each one closes.

FINDINGS	CRITICAL / HIGH	REMEDIATION WINDOW	FRAMEWORKS MAPPED
22	15	30 days	2

PREPARED

Confidential

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

October 09, 2026
Scope: essos.local

prepared for the named engagement

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Where your domain is *exposed*, and what to ship first.

100% of standard user accounts (6 of 6) hold a reachable path to full domain compromise. 14 reachable route(s) to full domain compromise.

This engagement against essos.local surfaced 22 confirmed findings, 9 of which sit on a validated path to full domain compromise. The remaining findings widen the attack surface without, on their own, completing that path.

The highest-confidence fix, proven in this environment, is Certificate Template Privilege Escalation (ADCS ESC1) on Template: ESC1, Domain Users (finding F-001, ADCS ESC1 - Misconfigured Certificate Template, ADscan Priority 9.9): it breaks the most validated attack paths ADscan walked against your domain. Close it first; the remaining findings follow on the 30-day roadmap below, in this same remediation order.

These findings map to 14 distinct controls across DORA, NIS2. The compliance-gap summary on this page lists the exact control codes each finding leaves open, so the roadmap doubles as an audit-remediation register.



CRITICAL · 9 (41%) HIGH · 6 (27%) MEDIUM · 4 (18%) LOW · 3 (14%)

CONFIRMED FINDINGS

22

surfaced in this engagement, de-duplicated across scope.

FINDINGS ON A VALIDATED PATH

9

findings whose technique sits on a path to full domain compromise, confirmed by configuration. Routes where only the entry step is proven and the chain is not walked end to end (partially validated) are detailed in the Security Assessment Report.

TOP EXPOSURE

Certificate Template Privilege Escalation (ADCS ESC1)

F-001 · ADscan Priority 9.9 · close it first.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

How to close each finding, *in remediation order*.

Each runbook is keyed to the finding ID in your Security Assessment Report. The report says what is wrong and how bad; this is the step-by-step fix, the exact commands, and how to prove it landed. ***The runbook number is the remediation order****, and runbook 01 is the single fix that reduces your exposure most. The first 9 runbooks lead because they break a validated attack path, each flagged* ***Path-breaker N of 9****, and the rest follow by severity. The ADscan Priority score beside each finding measures its severity; it is not the order. The first fix is* ***Certificate Template Privilege Escalation (ADCS ESC1)*** *(finding F-001); close it first. Those validated routes are what put 6 of 6 of your standard user accounts (100%) within reach of full domain compromise, so the path-breaker runbooks are where that exposure drops.*

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

01 ADCS ESC1 - Misconfigured Certificate Template

PATH-BREAKER 1 OF 9 · F-001 · CRITICAL · Priority 9.9 · ADCS · T1649

These 9 path-breaker fixes sit on the validated routes that put 6 of 6 of your standard user accounts (100%) within reach of full domain compromise. This one breaks an entry step on the largest share of them, which is why it leads.

AFFECTED

`Template: ESC1` `Domain Users` *enrollee*

RUNBOOK

PRIMARY Stop the template from honouring a requester-supplied SAN

STEPS

1. Open the Certificate Templates console (certtmpl.msc) and edit the affected template.
2. On the Subject Name tab, select 'Build from this Active Directory information' and clear 'Supply in the request': this removes the ENROLLEE_SUPPLIES_SUBJECT flag that lets the requester assert an arbitrary UPN.
3. If the template legitimately needs a custom SAN, instead require CA Manager approval (Issuance Requirements tab) so requests are not auto-issued.
4. Publish the change and confirm it replicated to all issuing CAs.

COMMANDS

```
GUI: certtmpl.msc > ESC1 > Properties > Subject Name tab > select 'Build from this Active Directory information', clear 'Supply in the request'
# Review the certificate template and confirm ENROLLEE_SUPPLIES_SUBJECT is no longer set on the template.
# Issuance requirement alternative (CA Manager approval):
certtmpl.msc > ESC1 > Issuance Requirements > 'CA certificate manager approval'
```

VALIDATION

> Re-run an AD CS template and CA security review and confirm the template no longer reports ESC1 / ENROLLEE_SUPPLIES_SUBJECT. A controlled enrollment specifying a SAN for another user should now be rejected or pended for approval.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Restrict enrolment and strip authentication EKUs

When: If the template's requester-supplied SAN cannot be removed because a provisioning workflow depends on it

STEPS

1. Remove broad enrolment grants (Authenticated Users, Domain Users, Domain Computers) from the template ACL; grant Enroll only to the specific service identity or security group that provisions certs.
2. Remove authentication EKUs (Client Authentication 1.3.6.1.5.5.7.3.2, Smart Card Logon 1.3.6.1.4.1.311.20.2.2, PKINIT, Any Purpose) so a minted cert cannot be used for AD authentication even if SAN abuse occurs.
3. Enable CA Manager approval as a second control on the template.
4. Plan to migrate to the Primary fix and remove the SAN-in-request capability.

COMMANDS

```
GUI: certtmpl.msc > ESC1 > Security tab > remove 'Enroll' / 'Autoenroll' from Authenticated
Users / Domain Users; grant Enroll only to a dedicated group
GUI: certtmpl.msc > ESC1 > Extensions tab > Application Policies > remove 'Client
Authentication' and 'Smart Card Logon'
# View ACEs on a published template object via PowerShell:
(Get-Acl 'AD:CN=ESC1,CN=Certificate Templates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=essos,DC=local').Access
```

VALIDATION

> An AD CS template security review no longer lists Authenticated Users/Domain Users with Enroll on the template, and the template's EKU set no longer includes a client-auth purpose.

CLOSES

DORA `art_9_4` `art_17` `art_19` NIS2 `21.2.h` `21.2.i`

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://learn.microsoft.com/en-us/defender-for-identity/security-assessment-edit-overly-permissive-template

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

02 AS-REP Roasting

PATH-BREAKER 2 OF 9 · F-016 · MEDIUM · Priority 6.9 · KERBEROS · T1558.004

AFFECTED

missandei EXPOSED *asrep-roastable-target*

RUNBOOK

PRIMARY Re-enable Kerberos pre-authentication on affected accounts

STEPS

1. Enumerate every account with pre-authentication disabled (DONT_REQ_PREAUTH, bit 0x400000 in userAccountControl).
2. For each, confirm with the application owner that pre-auth was not required for a genuine legacy reason.
3. Clear the 'Do not require Kerberos preauthentication' flag.

COMMANDS

```
# Find accounts with pre-auth disabled:
Get-ADUser -Filter 'useraccountcontrol -band 4194304' -Properties userAccountControl
# Re-enable pre-authentication on an account:
Set-ADAccountControl -Identity missandei -DoesNotRequirePreAuth $false
```

VALIDATION

> Get-ADUser missandei -Properties DoesNotRequirePreAuth | Select DoesNotRequirePreAuth (returns False). The account should no longer return an AS-REP without pre-auth (e.g. an AS-REP request now yields KDC_ERR_PREAUTH_REQUIRED).

FALLBACK Harden the account when pre-auth must stay disabled

When: If a legacy application or appliance genuinely requires pre-authentication to remain disabled

STEPS

1. Set a long random password (25+ chars) so any AS-REP hash is infeasible to crack offline.
2. Restrict the account to AES encryption types so the AS-REP is AES, not RC4.
3. Strip the account of any privileged group membership and scope its rights to the minimum.
4. Add the account to a Fine-Grained Password Policy enforcing a long minimum length and frequent rotation.

COMMANDS

```
$pw = [System.Web.Security.Membership]::GeneratePassword(28,6)
Set-ADAccountPassword missandei -Reset -NewPassword (ConvertTo-SecureString $pw -AsPlainText -
Force)
# AES-only (24 = AES128 + AES256):
Set-ADUser missandei -Replace @{'msDS-SupportedEncryptionTypes'=24}
```

VALIDATION

> Get-ADUser missandei -Properties msDS-SupportedEncryptionTypes,PasswordLastSet | Format-List (encryption types = 24). A controlled AS-REP request for the account should yield an AES hash ($krb5asrep$18$), not RC4 ($krb5asrep23).

CLOSES

DORA art_6 art_9_4 NIS2 21.2.h 21.2.j

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

REFS

- https://attack.mitre.org/techniques/T1558/004/
- https://learn.microsoft.com/en-us/defender-for-identity/cas-isp-unsecure-account-attributes

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

03 ADCS ESC5 - Vulnerable CA Object ACL

PATH-BREAKER 3 OF 9 · F-008 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

`braavos.essos.local (192.168.180.23)` *holder* · `CA: ESSOS-CA`

RUNBOOK

PRIMARY Lock down ACLs on CA infrastructure objects

STEPS

1. Audit the ACLs on the CA computer object, the Certification Authority object, the Enrollment Services container, and the NTAuthCertificates store.
2. Remove write, owner, and control rights from any non-PKI principal, leaving only PKI administrators and Enterprise Admins.
3. Run a full PKI health review to confirm no residual CA-level exposure.

COMMANDS

```
# Inspect the Enrollment Services and NTAuth ACLs:
dsacls "CN=Enrollment Services,CN=Public Key
Services,CN=Services,CN=Configuration,DC=essos,DC=local"
dsacls "CN=NTAuthCertificates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=essos,DC=local"
# Remove a non-PKI principal's rights:
dsacls "CN=NTAuthCertificates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=essos,DC=local" /R "ESSOS\braavos.essos.local"
```

VALIDATION

> dsacls on each CA object lists only PKI admins and Enterprise Admins with control rights; a re-run of an AD CS security review reports no ESC5 finding.

FALLBACK Tighten control of the CA host and audit changes

When: If a delegated operations team must retain limited CA host access

STEPS

1. Scope the operations team's rights to the specific service-management tasks they need, never object ownership or full control.
2. Restrict local administrator and RBCD configuration on the CA computer object.
3. Enable auditing on the CA objects so any ACL change is recorded.

COMMANDS

```
# Confirm no RBCD has been planted on the CA computer object:
Get-ADComputer <ca_host> -Properties msDS-AllowedToActOnBehalfOfOtherIdentity
# Audit: Advanced Audit Policy > DS Access > Audit Directory Service Changes = Success
```

VALIDATION

> msDS-AllowedToActOnBehalfOfOtherIdentity on the CA object is empty; Event ID 5136 fires on any change to the CA object ACLs.

CLOSES

DORA `art_9_4` · NIS2 `21.2.h` `21.2.i`

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/pki-design-guide

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

04 ADCS ESC9 - No Security Extension on Certificate Template

PATH-BREAKER 4 OF 9 · F-003 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

Template: ESC9 · Account Operators *enrollee* · khal.drogo *enrollee* · missandei *enrollee* · Spys *enrollee* · viserys.targaryen *enrollee*

RUNBOOK

PRIMARY Remove CT_FLAG_NO_SECURITY_EXTENSION so the SID security extension is embedded

STEPS

1. Identify the affected template and confirm the msPKI-Enrollment-Flag value has the CT_FLAG_NO_SECURITY_EXTENSION bit (0x80000 / decimal 524288) set.
2. Clear that bit so newly issued certificates embed the szOID_NTDS_CA_SECURITY_EXT extension binding the requester's SID.
3. Ensure DCs are in KB5014754 Full enforcement (StrongCertificateBindingEnforcement=2) so mapping relies on the embedded SID rather than UPN matching.
4. Restrict WriteProperty on user userPrincipalName to admins so the UPN-swap step of the attack is not possible.

COMMANDS

```
# Review the certificate template's enrollment flags for the abusable setting (read the flag below).
# Read the enrollment flag; check for CT_FLAG_NO_SECURITY_EXTENSION:
Get-ADObject -SearchBase ("CN=Certificate Templates,CN=Public Key Services,CN=Services," + (Get-ADRootDSE).configurationNamingContext) -Filter "Name -eq 'VulnTemplate'" -Properties msPKI-Enrollment-Flag
# Clear ONLY the NO_SECURITY_EXTENSION bit, preserving every other enrollment flag (do NOT zero the whole value: that would drop AUTO_ENROLLMENT and others):
$t = Get-ADObject -SearchBase ("CN=Certificate Templates,CN=Public Key Services,CN=Services," + (Get-ADRootDSE).configurationNamingContext) -Filter "Name -eq 'VulnTemplate'" -Properties msPKI-Enrollment-Flag
Set-ADObject $t -Replace @{'msPKI-Enrollment-Flag' = ($t.'msPKI-Enrollment-Flag' -band -bnot 0x80000)}
# GUI: certtmpl.msc > template > Subject Name tab > do NOT check 'Do not include security extension'.
# Enforce strong mapping on DCs:
reg add HKLM\SYSTEM\CurrentControlSet\Services\Kdc /v StrongCertificateBindingEnforcement /t REG_DWORD /d 2 /f
```

VALIDATION

> The template's msPKI-Enrollment-Flag no longer has the 0x80000 bit; a freshly issued certificate from it contains the SID security extension (inspect with certutil -dump). DCs report StrongCertificateBindingEnforcement=2. ADscan re-scan should no longer flag ESC9.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Contain via enrollment restriction + UPN write lockdown while the flag is corrected

When: If clearing the flag requires a change window or breaks a downstream consumer that depends on the legacy behaviour

STEPS

1. Restrict Enroll on the affected template to a minimal audited set so an attacker cannot obtain a forged certificate.
2. Lock down write access to userPrincipalName across the directory so the UPN-impersonation pivot is unavailable (remove GenericWrite / Write-userPrincipalName from non-admin principals).
3. Enable manager approval on the template and schedule the flag clear from the Primary option.

COMMANDS

```
# Find non-admin principals with write over UPN on user objects (native, resolves the
attribute's schema GUID first):
$upnGuid = (Get-ADObject -SearchBase (Get-ADRootDSE).schemaNamingContext -LDAPFilter
'(lDAPDisplayName=userPrincipalName)' -Properties schemaIDGUID).schemaIDGUID
Get-ADUser -Filter * -ResultPageSize 200 | ForEach-Object { (Get-Acl
"AD:$($_.DistinguishedName)").Access } | ? { $_.ObjectType -eq $upnGuid -and
$_.ActiveDirectoryRights -match 'Write' }
# Tighten template enrollment + approval via certtmpl.msc (Security + Issuance Requirements
tabs).
# Remove an over-broad UPN-write grant with dsacls (example):
dsacls "OU=Users,DC=essos,DC=local" /R "ESSOS\<upn_write_principal>"
```

VALIDATION

> Low-privilege users can no longer enroll in the template (or are held for approval); no non-admin principal retains Write over userPrincipalName. Confirm with the ACL audit above.

CLOSES DORA `art_9_4` NIS2 `21.2.h`

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://support.microsoft.com/en-us/topic/kb5014754-certificate-based-authentication-changes-on-windows-domain-controllers-ad2c23b0-15d8-4340-a468-4d4f3b188f16

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

05 LAPS Password Readable by Non-Admins

PATH-BREAKER 5 OF 9 · F-011 · HIGH · Priority 8.8 · LAPS · T1555

AFFECTED

`Spys → braavos.essos.local (192.168.180.23)`

`jorah.mormont → braavos.essos.local (192.168.180.23)`

RUNBOOK

PRIMARY Remove non-admin read access to the LAPS password attribute and rotate

STEPS

1. Enumerate which principals currently have read access to the LAPS password attribute (ms-Mcs-AdmPwd for legacy LAPS, msLAPS-Password / msLAPS-EncryptedPassword for Windows LAPS) on the computer OUs.
2. Remove read (and 'All Extended Rights' / GenericAll, which implies read of confidential attributes) from any broad or non-admin group at the OU level.
3. Confirm only the intended administrative tier retains read; verify no inherited or nested-group grant re-introduces access.
4. Rotate ALL LAPS passwords immediately, because any currently-readable password must be assumed exposed.

COMMANDS

```
# Find who can read the attribute (review):
Find-AdmPwdExtendedRights -Identity "OU=Workstations,DC=essos,DC=local"   # legacy LAPS module
# Native: inspect the OU ACL for read/extended-rights grants:
(Get-Acl "AD:OU=Workstations,DC=essos,DC=local").Access | ? { $_.ActiveDirectoryRights -match
'ReadProperty|ExtendedRight|GenericAll' }
# Remove an over-broad trustee with dsacls (example):
dsacls "OU=Workstations,DC=essos,DC=local" /R "ESSOS\Domain Users"
# Re-grant read only to the admin tier (Windows LAPS):
Set-LapsADReadPasswordPermission -Identity "OU=Workstations,DC=essos,DC=local" -
AllowedPrincipals "ESSOS\LAPS-Admins"
# Force rotation on all managed machines (Windows LAPS):
Get-ADComputer -Filter * -SearchBase "OU=Workstations,DC=essos,DC=local" | ForEach-Object {
Reset-LapsPassword -Identity $_.Name }
```

VALIDATION

> Re-run Find-AdmPwdExtendedRights (or the ACL read) and confirm only the admin tier can read the attribute; Get-LapsADPassword as a non-admin is denied. ADscan re-scan should no longer flag laps_readable.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Tighten via OU restructuring + auditing while delegation is untangled

When: If LAPS read access was delegated through complex nested groups that cannot be cleanly stripped at once

STEPS

1. Move the affected computers under an OU whose ACL grants LAPS read only to the admin tier, so the over-broad inherited delegation no longer applies to them.
2. Enable auditing on the LAPS attribute so any read is logged (Event ID 4662 on the confidential attribute) and alert on reads from non-admin principals.
3. Work through and remove the legacy nested-group delegation, then converge on the Primary option, rotating passwords as access is tightened.

COMMANDS

```
# Enable SACL auditing on the OU for the LAPS attribute (GUI: dsa.msc > View > Advanced Features > OU > Properties > Security > Advanced > Auditing > add principal, 'Read all properties' = Success).
# Review LAPS attribute reads:
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4662} -MaxEvents 100 | ? { $_.Message -match 'ms-Mcs-AdmPwd|msLAPS' }
```

VALIDATION

> Event ID 4662 records LAPS attribute reads; the affected computers now inherit an OU ACL that excludes non-admin read. A non-admin read attempt is logged and (after Primary cleanup) denied.

CLOSES DORA art_9_2 NIS2 21.2.i

REFS

- https://attack.mitre.org/techniques/T1555/
- https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-overview
- https://learn.microsoft.com/en-us/defender-for-identity/cas-isp-laps

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

06 ADCS ESC4 - Vulnerable Certificate Template ACL

PATH-BREAKER 6 OF 9 · F-010 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

Template: ESC4 · khal.drogo *holder*

RUNBOOK

PRIMARY Remove dangerous write ACEs from the template object

STEPS

1. Read the security descriptor of the affected template object under CN=Certificate Templates,CN=Public Key Services,CN=Services in the Configuration NC and enumerate principals holding WriteProperty, WriteDacl, WriteOwner, or GenericWrite / GenericAll.
2. Confirm which are legitimate (Enterprise Admins, Domain Admins, PKI administrators) and remove the rest.
3. Remove the unauthorised write ACEs so only the PKI admin tier can modify the template configuration or its DACL.
4. Because ESC4 lets an attacker temporarily transform the template into an ESC1 condition, also audit the template's current EKU, SAN-supply flag (CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT) and manager-approval setting in case it was already abused and reverted.

COMMANDS

```
# Review who can write the template (inspect the template ACL below for write-class rights
held by non-PKI principals).
# Native: inspect the template ACL:
$tpl = "CN=VulnTemplate,CN=Certificate Templates,CN=Public Key Services,CN=Services," + (Get-
ADRootDSE).configurationNamingContext
(Get-Acl "AD:$tpl").Access | ? { $_.ActiveDirectoryRights -match 'Write|GenericAll' }
# Remove a specific unauthorised trustee with dsacls:
dsacls "CN=VulnTemplate,CN=Certificate Templates,CN=Public Key
Services,CN=Services,DC=essos,DC=local" /R "ESSOS\khal.drogo"
```

VALIDATION

> Re-read the template ACL and confirm only the PKI admin tier retains write access; ADscan re-scan should no longer flag ESC4 for that template.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Reset the template ACL to the default PKI-admin baseline and lock ownership

When: If the ACL has been tampered with broadly or the affected principals cannot be cleanly enumerated

STEPS

1. Take ownership of the template object back to a PKI administrator / Enterprise Admins, in case WriteOwner was abused to change it.
2. Re-apply a known-good ACL: SYSTEM and the PKI admin groups Full Control, Authenticated Users / Domain Users read-only (and Enroll only where legitimately required).
3. Enable directory-service object-change auditing on the Certificate Templates container so future ACL edits are logged (Event ID 5136).

COMMANDS

```
# Reset ownership to the admin tier (dsacls):
dsacls "CN=VulnTemplate,CN=Certificate Templates,CN=Public Key
Services,CN=Services,DC=essos,DC=local" /takeownership
# Enable change-auditing (SACL) on the container via the ActiveDirectory AD: drive so future
ACL edits log Event ID 5136:
$p='AD:\CN=Certificate Templates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=essos,DC=local'; $acl=Get-Acl $p -Audit;
$acl.AddAuditRule((New-Object
System.DirectoryServices.ActiveDirectoryAuditRule([System.Security.Principal.NTAccount]'Everyo
ne','WriteProperty','Success'))); Set-Acl $p $acl
# Review template-modification events on a DC:
Get-WinEvent -FilterHashtable @{LogName='Security';Id=5136} -MaxEvents 50
```

VALIDATION

> (Get-Acl) on the template shows the PKI-admin owner and the baseline ACL with no extraneous write trustees; Event ID 5136 appears for any subsequent template change.

CLOSES DORA `art_9_4` NIS2 `21.2.h` `21.2.i`

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://learn.microsoft.com/en-us/defender-for-identity/security-assessment-edit-misconfigured-acl

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

07 ADCS ESC2 - Any Purpose Certificate Template

PATH-BREAKER 7 OF 9 · F-005 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

Template: ESC2 · Domain Users *enrollee*

RUNBOOK

PRIMARY Replace the Any Purpose / no-EKU configuration with scoped EKUs

STEPS

1. Identify the affected template in the Certificate Templates console (certtmpl.msc) and confirm it carries the Any Purpose EKU (OID 2.5.29.37.0) or has no Application Policies / EKU at all.
2. Duplicate the template, give the copy only the specific EKUs the business use case requires (e.g. Server Authentication 1.3.6.1.5.5.7.3.1 for TLS, or Document Signing): never Any Purpose and never an empty EKU set.
3. On the Security tab, remove Enroll/Autoenroll from broad principals (Authenticated Users, Domain Users, Domain Computers) and grant it only to the groups that legitimately need this certificate.
4. Publish the new template on the CA, migrate consumers to it, then unpublish and delete the vulnerable template.

COMMANDS

```
# Review certificate templates for the abusable EKU configuration.
# Native: read the template's EKU (pKIExtendedKeyUsage) and flags:
Get-ADObject -SearchBase ("CN=Certificate Templates,CN=Public Key Services,CN=Services," +
(Get-ADRootDSE).configurationNamingContext) -Filter * -Properties pKIExtendedKeyUsage,msPKI-
Certificate-Name-Flag | Select Name,pKIExtendedKeyUsage
# GUI: certtmpl.msc > template > Extensions tab > Application Policies > remove 'Any Purpose',
add the specific EKU(s) required.
# Publish/unpublish via the CA console (certsrv.msc) > Certificate Templates > New / Delete.
```

VALIDATION

> Re-run the template audit and confirm no template advertises the Any Purpose EKU or an empty EKU set with low-privilege enrollment. An ADscan re-scan should no longer flag ESC2.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Lock down enrollment and require manager approval while the EKU is corrected

When: If the template is in active production use and cannot be replaced immediately

STEPS

1. Immediately tighten enrollment: remove Enroll from broad groups so only a small, audited set of principals can request the template.
2. Enable 'CA certificate manager approval' on the template so every issuance is held pending and manually approved by a PKI officer.
3. Pair this with monitoring on the CA (issued-certificate log) and schedule the EKU correction in the Primary option as the permanent fix.

COMMANDS

```
# GUI: certtmpl.msc > template > Issuance Requirements tab > check 'CA certificate manager approval'.
# GUI: certtmpl.msc > template > Security tab > remove Enroll from Authenticated Users / Domain Users.
# Verify pending-approval requests on the CA:
certutil -view -restrict "Disposition=9"   # 9 = pending
```

VALIDATION

> Submit a test enrollment as a low-privilege user and confirm it lands in the Pending Requests queue on the CA rather than being auto-issued; confirm broad groups can no longer enroll.

CLOSES DORA art_9_4 NIS2 21.2.h 21.2.i

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://learn.microsoft.com/en-us/defender-for-identity/security-assessment-edit-overly-permissive-template

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

08 ADCS ESC3 - Enrollment Agent Template Abuse

PATH-BREAKER 8 OF 9 · F-006 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

Template: ESC3-CRA

Domain Users *enrollee*

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

RUNBOOK

PRIMARY

Restrict the enrollment-agent template and enforce Enrollment Agent Restrictions on the CA

STEPS

1. Identify templates carrying the Certificate Request Agent EKU (OID 1.3.6.1.4.1.311.20.2.1) and remove Enroll rights from any broad/low-privilege principals: keep it only for the dedicated enrollment-agent service identities.
2. On the CA, configure Enrollment Agent Restrictions so each agent may request only specific templates and only on behalf of specific target groups (not 'Everyone').
3. On the second-stage templates that permit agent enrollment, require manager approval and restrict which agents are authorised.
4. Audit any certificates already issued through the agent chain for signs of abuse.

COMMANDS

```
# Review certificate templates and CA enrollment-agent settings for the abusable
configuration.
# CA GUI: certsrv.msc > right-click CA > Properties > Enrollment Agents tab > switch from 'Do
not restrict' to 'Restrict enrollment agents' and scope agents -> templates -> managed groups.
# Template GUI: certtmpl.msc > agent template > Security tab > remove Enroll from broad
groups.
# List who can enroll in a template (native ACL read):
Get-ADObject -SearchBase ("CN=Certificate Templates,CN=Public Key Services,CN=Services," +
(Get-ADRootDSE).configurationNamingContext) -Filter "Name -eq 'EnrollmentAgent'" -Properties
nTSecurityDescriptor
```

VALIDATION

> On the CA, confirm Enrollment Agent Restrictions are set to 'Restrict' with explicit agent/template/group scoping; attempt a low-privilege enrollment in the agent template and confirm it is denied. ADscan re-scan should no longer flag ESC3.

FALLBACK

Disable / unpublish the enrollment-agent template pending redesign

When: If no business process currently depends on enrollment-on-behalf-of and the chain must be closed immediately

STEPS

1. Unpublish the Certificate Request Agent template from every issuing CA so it can no longer be requested.
2. If enrollment-on-behalf-of is genuinely needed later, reintroduce it with the hardened Primary configuration rather than the original permissive template.
3. Confirm no automated service relied on the agent chain before unpublishing.

COMMANDS

```
# CA GUI: certsrv.msc > Certificate Templates > right-click the agent template > Delete
(unpublish from this CA).
# Verify it is no longer offered for enrollment:
certutil -CATemplates   # the agent template should be absent
```

VALIDATION

> certutil -CATemplates no longer lists the enrollment-agent template on any issuing CA; an enrollment attempt for it fails with template-not-found.

CLOSES

DORA art_9_4 NIS2 21.2.h 21.2.i

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

- https://learn.microsoft.com/en-us/defender-for-identity/security-assessment-edit-overly-permissive-template

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

09 ADCS ESC8 - NTLM Relay to Web Enrollment

PATH-BREAKER 9 OF 9 · F-007 · HIGH · Priority 9 · ADCS · T1649

AFFECTED

CA: ESSOS-CA

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

RUNBOOK

PRIMARY Enable Extended Protection for Authentication (EPA) and require HTTPS on the enrollment endpoints

STEPS

1. On the CA's web-enrollment IIS server, set Extended Protection to Required for the certsrv application (and the CES/NDES applications if present): EPA channel-binds the TLS session so a relayed NTLM authentication is rejected.
2. Disable plain HTTP for web enrollment and require HTTPS so there is a TLS channel for EPA to bind to.
3. Restart IIS to apply.
4. Apply this alongside the LDAP-signing/channel-binding and coercion mitigations so the relay primitive itself is closed, not just this endpoint.

COMMANDS

```
# Require EPA on certsrv (IIS appcmd):
%windir%\system32\inetsrv\appcmd set config "Default Web Site/certsrv"
/section:windowsAuthentication /extendedProtection.tokenChecking:"Require"
/extendedProtection.flags:"None" /commit:apphost
# GUI alternative: IIS Manager > Sites > Default Web Site > certsrv > Authentication > Windows
Authentication > Advanced Settings > Extended Protection = Required.
# Require HTTPS for the certsrv app (IIS Manager > certsrv > SSL Settings > 'Require SSL').
iisreset
```

VALIDATION

> From a test host, attempt an NTLM relay to /certsrv and confirm it now fails with an authentication/channel-binding error; the certsrv app should reject plain HTTP. ADscan re-scan should no longer flag ESC8.

FALLBACK Disable HTTP web enrollment entirely and mitigate coercion

When: If web enrollment (certsrv/CES) is not operationally required, or EPA cannot be enabled on the IIS version in use

STEPS

1. Remove or stop the Certificate Authority Web Enrollment role / the certsrv IIS application so there is no HTTP(S) relay target.
2. Move any genuine enrollment need to autoenrollment or the MMC/DCOM enrollment path.
3. Independently close the coercion primitive that feeds the relay: patch PetitPotam (MS-EFSRPC), disable the Print Spooler on DCs/servers that do not print, and block inbound RPC coercion where feasible.

COMMANDS

```
# Remove the Web Enrollment role service:
Remove-WindowsFeature ADCS-Web-Enrollment
# Disable the Print Spooler on a DC (kills PrinterBug coercion):
Stop-Service Spooler -Force; Set-Service Spooler -StartupType Disabled
# Confirm the certsrv endpoint is gone:
Invoke-WebRequest http://<ca_host>/certsrv/ -UseBasicParsing   # should fail to connect
```

VALIDATION

> The /certsrv endpoint no longer responds; Get-Service Spooler shows Stopped/Disabled on DCs. A coercion + relay attempt against the CA fails because there is no web-enrollment target.

CLOSES DORA `art_9_4` `art_9_3` NIS2 `21.2.h` `21.2.e`

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/web-enrollment

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

10 noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)

F-002 · CRITICAL · Priority 9.8 · CVE · T1068 T1558

AFFECTED

`meereen.essos.local (192.168.180.12)` *vulnerable-host*

RUNBOOK

PRIMARY Patch all Domain Controllers (the only complete fix)

STEPS

1. Apply the November 2021 (or later cumulative) security updates on EVERY Domain Controller: both KB5008380 (the initial fix) and the DC-specific update for the OS version are required to close the two chained CVEs.
2. Confirm every writable DC is patched; a single unpatched DC leaves the chain exploitable because the attacker can target that KDC.
3. Reboot DCs as the update requires and verify the build/hotfix is present.
4. Keep monitoring Event IDs 4741/4742 for sAMAccountName values that collide with DC names during and after rollout.

COMMANDS

```
# Confirm the patch is installed on each DC (replace KB as appropriate for the OS):
Get-HotFix -Id KB5008380   # and the OS-specific DC update
# Inventory DC patch levels from one management host:
Get-ADDomainController -Filter * | ForEach-Object { Invoke-Command -ComputerName $_.HostName -
ScriptBlock { (Get-HotFix | Sort InstalledOn -Desc | Select -First 5) } }
# Hunt for the spoofing primitive in the Security log:
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4741,4742} -MaxEvents 200 | ? {
$_.Message -match 'SAM Account Name' }
```

VALIDATION

> Get-HotFix confirms the required KBs on every DC; a controlled noPac exploitation attempt (lab only) fails after patching. ADscan re-scan should no longer flag noPac.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Remove the prerequisite by setting ms-DS-MachineAccountQuota to 0

When: As a hardening measure while patching is scheduled, or where a legacy DC cannot yet be patched

STEPS

1. Set ms-DS-MachineAccountQuota to 0 on the domain object so standard users can no longer create the machine account the attack relies on (this does NOT fix the underlying CVEs; it removes the default creation path).
2. Where specific teams genuinely need to domain-join machines, grant the 'Create Computer Objects' / 'Add workstations to domain' right to a delegated group on a specific OU instead of relying on the quota.
3. Treat this strictly as a stopgap and complete the patching in the Primary option: an attacker who already controls a machine account can still chain the CVEs.

COMMANDS

```
# Read the current quota:
Get-ADObject (Get-ADDomain).DistinguishedName -Properties ms-DS-MachineAccountQuota
# Set it to 0:
Set-ADDomain -Identity essos.local -Replace @{'ms-DS-MachineAccountQuota'=0}
# Delegate join rights to a specific group on an OU instead (GUI: dsa.msc > OU > Delegate Control > 'Create/delete Computer objects').
```

VALIDATION

> Get-ADObject shows ms-DS-MachineAccountQuota = 0; a standard user attempting New-ADComputer / djoin is denied. Note this is mitigation only: the Primary patch remains required.

CLOSES

DORA `art_9_4` `art_9_2` NIS2 `21.2.e` `21.2.i`

REFS

- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-42287
- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-42278
- https://nvd.nist.gov/vuln/detail/CVE-2021-42287
- https://nvd.nist.gov/vuln/detail/CVE-2021-42278
- https://exploit.ph/cve-2021-42287-cve-2021-42278-weaponisation.html

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

11 ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

F-004 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

- `Template: KerberosAuthentication` *vulnerable-template*
- `Enterprise Read-only Domain Controllers` *holder*

RUNBOOK

PRIMARY Remove weak altSecurityIdentities explicit mappings

STEPS

1. Audit altSecurityIdentities on all accounts and identify weak mapping formats (issuer-only, subject-only) that are not strongly bound to the holder's SID.
2. Replace them with strong mappings (SKI or the SHA1-PublicKey / Issuer+SerialNumber forms) or remove them.
3. Enforce KB5014754 Full enforcement so weak explicit mappings are rejected.

COMMANDS

```
# List accounts (users AND computers) carrying an explicit certificate mapping, then pick the weakly-mapped one:
Get-ADObject -LDAPFilter '(altSecurityIdentities=*)' -Properties altSecurityIdentities
# On that mapped account, replace the weak mapping with a strong, SID-bound one (object-class-agnostic, since the mapped account may be a computer):
Get-ADObject -LDAPFilter '(sAMAccountName=<mapped_account>)' | Set-ADObject -Replace @{altSecurityIdentities='X509:<SKI>0123456789abcdef...'}
```

VALIDATION

> No account carries an issuer-only or subject-only altSecurityIdentities value; a certificate crafted to match a weak format (review-only) no longer authenticates.

FALLBACK Restrict enrollment on templates that feed the abuse

When: If a legacy integration depends on an explicit mapping that cannot be reformatted yet

STEPS

1. Lock enrollment on any template capable of minting a certificate that would satisfy the weak mapping to a tightly-scoped group.
2. Disable enrollee-supplied subject on those templates.
3. Plan reformatting of the explicit mapping to a SID-bound form and track it to completion.

COMMANDS

```
# Review enrollment rights on the suspect template:
certutil -v -template "KerberosAuthentication" | findstr /i 'Enroll'
# Tighten enrollment ACLs in the Certificate Templates console (certtmpl.msc) to a named group.
```

VALIDATION

> Only the scoped group can enroll the suspect template; the legacy mapping is queued for reformatting in the remediation register.

CLOSES DORA `art_9_4` NIS2 `21.2.h`

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

- https://support.microsoft.com/en-us/topic/kb5014754-certificate-based-authentication-changes-on-windows-domain-controllers-ad2c23b0-15d8-4340-a468-4d4f3b188f16

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

12 ADCS ESC7 - Certificate Authority Privilege Abuse

F-009 · CRITICAL · Priority 9 · ADCS · T1649

AFFECTED

`braavos.essos.local (192.168.180.23)` *holder* `CA: ESSOS-CA`

RUNBOOK

PRIMARY Remove Manage CA / Manage Certificates from non-PKI principals and enforce separation of duties

STEPS

1. Enumerate the CA security roles and identify every principal holding Manage CA (CA Administrator) or Manage Certificates (Certificate Manager).
2. Remove both rights from any non-PKI-administrator principal.
3. Enforce separation of duties: do not let the same identity hold both Manage CA and Manage Certificates, since together they enable submit-then-self-approve of a forged-SAN request.
4. If Manage Certificates must remain delegated, scope Certificate Manager Restrictions so the officer can only manage requests from specific groups.

COMMANDS

```
# Review CA role assignments (read the CA security descriptor below for Manage CA / Manage Certificates held by non-PKI principals).
# Native: read the CA security descriptor:
certutil -getreg CA\Security
# GUI: certsrv.msc > right-click CA > Properties > Security tab > remove 'Manage CA' / 'Issue and Manage Certificates' from unauthorised principals.
# Officer restrictions: certsrv.msc > CA > Properties > Certificate Managers tab > Restrict and scope to specific groups.
```

VALIDATION

> certutil -getreg CA\Security shows only authorised PKI administrators with Manage CA / Manage Certificates, and no single principal holds both. ADscan re-scan should no longer flag ESC7.

FALLBACK Constrain the privilege impact pending role cleanup

When: If an operational team temporarily requires Manage Certificates and cannot be removed immediately

STEPS

1. Apply Certificate Manager Restrictions so the delegated officer can only approve requests for a narrow, non-privileged set of groups: never Domain Admins / Tier-0.
2. Enable the CA audit log for 'Issue and manage certificate requests' and 'Change CA configuration' so submit/approve actions are recorded.
3. Alert on any pending request whose subject/SAN names a privileged account, and complete the full role cleanup in the Primary option.

COMMANDS

```
# Enable CA auditing for all events (then review Security log):
certutil -setreg CA\AuditFilter 127
net stop certsvc && net start certsvc
# Review issued/pending requests on the CA:
certutil -view -restrict "Disposition=9"   # pending approval
# GUI officer scoping: certsrv.msc > CA > Properties > Certificate Managers tab > Restrict.
```

VALIDATION

> Certificate Manager Restrictions are enabled and scoped to non-privileged groups; CA AuditFilter reads 127 and the Security log records issue/approve events. A self-approved request for a privileged subject is blocked or alerts.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

CLOSES DORA art_9_4 NIS2 21.2.h 21.2.i

REFS

- https://attack.mitre.org/techniques/T1649/
- https://posts.specterops.io/certified-pre-owned-d95910965cd2
- https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/manage-role-services

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

13 PrintNightmare Vulnerable Hosts Detected

F-012 · HIGH · Priority 8.8 · CVE · T1068

AFFECTED

- `braavos.essos.local (192.168.180.23)` *vulnerable-host*
- `meereen.essos.local (192.168.180.12)` *vulnerable-host*

RUNBOOK

PRIMARY — Patch and disable the Print Spooler where unused

STEPS

1. Apply the CVE-2021-34527 updates on all hosts.
2. Disable the Print Spooler service on Domain Controllers and any server that does not print.
3. Restrict point-and-print driver installation to administrators via the package-point-and-print policy.

COMMANDS

```
# Disable the spooler where print is not needed (especially DCs):
Set-Service -Name Spooler -StartupType Disabled; Stop-Service Spooler
# Restrict driver installs to admins (RestrictDriverInstallationToAdministrators):
reg add 'HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers\PointAndPrint' /v
RestrictDriverInstallationToAdministrators /t REG_DWORD /d 1 /f
```

VALIDATION

> Get-Service Spooler shows Stopped/Disabled on DCs; RestrictDriverInstallationToAdministrators reads 1 where the spooler must stay on.

FALLBACK — Block remote spooler connections where printing must stay enabled

When: If a print server genuinely needs the spooler running

STEPS

1. Keep the spooler only on dedicated print servers, patched and hardened.
2. Use the 'Allow Print Spooler to accept client connections' policy to stop remote RPC where local printing suffices.
3. Restrict the directory from which printer drivers can load to a trusted, admin-controlled path.

COMMANDS

```
# Disable inbound client connections to the spooler (RegisterSpoolerRemoteRpcEndPoint):
reg add 'HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers' /v
RegisterSpoolerRemoteRpcEndPoint /t REG_DWORD /d 2 /f
Restart-Service Spooler
```

VALIDATION

> The host no longer accepts remote AddPrinterDriverEx RPC; a PrintNightmare check (review-only) against it fails to load a remote driver.

CLOSES

DORA `art_9_4` `art_11` `art_17` `art_19` NIS2 `21.2.e`

REFS

- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527
- https://nvd.nist.gov/vuln/detail/CVE-2021-34527
- https://attack.mitre.org/techniques/T1068/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

14 Domain Controller Accepts NTLMv1 Authentication

F-013 · HIGH · Priority 8.5 · AUTHENTICATION · T1557 T1078

AFFECTED

`meereen.essos.local (192.168.180.12)`

RUNBOOK

PRIMARY Refuse LM and NTLMv1 domain-wide (LmCompatibilityLevel 5)

STEPS

1. First enable NTLM auditing for a baseline window to discover which clients still negotiate LM/NTLMv1 (avoid breaking them blind).
2. In a GPO linked to the Domain Controllers OU (and a separate policy for member servers / workstations), set the LAN Manager authentication level to 'Send NTLMv2 response only. Refuse LM & NTLM'.
3. Set the minimum session security for NTLM SSP to require NTLMv2 session security and 128-bit encryption on both client and server.
4. Run gpupdate and validate before widening the scope.

COMMANDS

```
GPO path: Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > 'Network security: LAN Manager authentication level' = 'Send NTLMv2 response only. Refuse LM & NTLM'
# Equivalent registry value (LmCompatibilityLevel 5 = refuse LM & NTLMv1, accept NTLMv2):
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v LmCompatibilityLevel /t REG_DWORD /d 5 /f
# Require NTLMv2 + 128-bit on min session security (value 537395200):
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0 /v NtlmMinClientSec /t REG_DWORD /d 537395200 /f
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0 /v NtlmMinServerSec /t REG_DWORD /d 537395200 /f
gpupdate /force
```

VALIDATION

> On a DC, reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v LmCompatibilityLevel returns 5. Then attempt an NTLMv1 authentication in a controlled test and confirm it is rejected; review Event ID 4624 / NTLM operational auditing for any residual NTLMv1 (Package Name 'NTLM V1').

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Scope NTLMv1 to an audited allow-list while legacy app is fixed

When: If a legacy application or appliance still requires NTLMv1 and cannot be patched immediately

STEPS

1. Enable 'Network security: Restrict NTLM' auditing on DCs to identify exactly which servers receive the legacy NTLM traffic.
2. Set 'Restrict NTLM: Add server exceptions in this domain' to the specific FQDNs that genuinely require it, then switch the DC policy to 'Deny all' for everything else.
3. Track each exception in a register with an owner and a removal deadline, and pair with SMB/LDAP signing + coercion mitigations to limit relay even for the allow-listed hosts.
4. Decommission or upgrade the legacy app, then remove the exception and move to the Primary option.

COMMANDS

```
GPO path: Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' = 'Enable all'
GPO path: '...Restrict NTLM: Add server exceptions in this domain' = legacyapp.essos.local (one FQDN per line)
GPO path: '...Restrict NTLM: NTLM authentication in this domain' = 'Deny all'  (exceptions above remain allowed)
```

VALIDATION

> Review the NTLM operational log (Applications and Services Logs > Microsoft > Windows > NTLM) for Event IDs 8001-8004: only the allow-listed FQDN should appear as permitted NTLM; all other NTLM attempts should be blocked.

CLOSES

DORA `art_6` `art_9_3` `art_9_4` NIS2 `21.2.e` `21.2.h`

REFS

- https://learn.microsoft.com/en-us/troubleshoot/windows-server/windows-security/audit-domain-controller-ntlmv1
- https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-lan-manager-authentication-level

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

15 gMSA Password Readable by Non-Admins

F-014 · HIGH · Priority 7.5 · GMSA · T1555

AFFECTED

`braavos.essos.local (192.168.180.23) → gmsaDragon$`

RUNBOOK

PRIMARY **Restrict msDS-GroupMSAMembership to the hosts that run the service**

STEPS

1. Read the PrincipalsAllowedToRetrieveManagedPassword (msDS-GroupMSAMembership) for each affected gMSA and identify every principal that can retrieve the password blob.
2. Remove any user accounts and broad/low-privilege groups; the value should list ONLY the computer accounts (or a tightly scoped host group) that actually run the service.
3. Set the attribute to the corrected principal set.
4. Because gMSA keys are KDS-derived and rotate automatically, no manual rotation is needed, but if abuse is suspected, you can force a key change by recreating the gMSA, and review the gMSA's own privileges for blast radius.

COMMANDS

```
# Read who can retrieve the password:
Get-ADServiceAccount -Identity 'gmsadragon$' -Properties
PrincipalsAllowedToRetrieveManagedPassword | Select -Expand
PrincipalsAllowedToRetrieveManagedPassword
# Restrict to the specific service hosts (overwrites the list):
Set-ADServiceAccount -Identity 'gmsadragon$' -PrincipalsAllowedToRetrieveManagedPassword
"ESSOS\<service_host>$"
```

VALIDATION

> Get-ADServiceAccount ... shows only the intended service hosts; a non-authorised principal calling Get-ADServiceAccount -Properties msDS-ManagedPassword cannot retrieve the blob. ADscan re-scan should no longer flag gmsa_readable.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Replace the gMSA / re-scope membership when the allowed list cannot be cleanly trimmed

When: If the membership is fronted by a group whose members cannot all be removed at once, or the gMSA's privileges are high enough that exposure must be assumed

STEPS

1. Create a new, narrowly-scoped host group containing only the service hosts and point PrincipalsAllowedToRetrieveManagedPassword at that group instead of the over-broad one.
2. If the gMSA password is assumed exposed, provision a replacement gMSA, migrate the service to it, then disable/remove the old account so the leaked key is retired.
3. Reduce the gMSA's own rights to least privilege so any future exposure has minimal blast radius.

COMMANDS

```
# Create a scoped host group and point the gMSA at it:
New-ADGroup -Name '<new_host_group>' -GroupScope Global -Path 'OU=Groups,DC=essos,DC=local'
Add-ADGroupMember -Identity '<new_host_group>' -Members <service_host>$
Set-ADServiceAccount -Identity 'gmsadragon$' -PrincipalsAllowedToRetrieveManagedPassword
'<new_host_group>'
# Provision a replacement gMSA if rotation is needed:
New-ADServiceAccount -Name <new_gmsa_name> -DNSHostName <new_gmsa_name>.essos.local -
PrincipalsAllowedToRetrieveManagedPassword '<new_host_group>'
```

VALIDATION

> The allowed-list now resolves only to the service hosts; if replaced, the old gMSA is disabled and the service authenticates as the new account. Confirm with Get-ADServiceAccount and a service logon test.

CLOSES DORA `art_9_2` NIS2 `21.2.i`

REFS

- https://attack.mitre.org/techniques/T1555/
- https://learn.microsoft.com/en-us/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

16 SMBv1 Protocol Enabled

F-015 · HIGH · Priority 7.5 · NETWORK SECURITY · T1210

AFFECTED

`braavos.essos.local (192.168.180.23)` `meereen.essos.local (192.168.180.12)`

RUNBOOK

PRIMARY Disable SMBv1 server and client across the estate

STEPS

1. Disable the SMBv1 server on every host and remove the optional feature, starting with DCs, Tier-0, and exposed servers.
2. Confirm the MS17-010 patch is present on any host that briefly remained SMBv1-capable.
3. Roll the change out by GPO so new hosts inherit it.

COMMANDS

```
Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart
# Verify MS17-010 patch (build-specific KB, e.g. KB4012212):
Get-HotFix -Id KB4012212 -ErrorAction SilentlyContinue
```

VALIDATION

> Get-SmbServerConfiguration EnableSMB1Protocol returns False; an SMB version scan no longer negotiates NT LM 0.12.

FALLBACK Isolate hosts pinned to SMBv1 by a legacy dependency

When: If an old NAS or appliance still requires SMBv1

STEPS

1. Confine SMBv1 to a single isolated segment and restrict inbound 445 to the one client that needs it.
2. Keep SMBv1 disabled everywhere else.
3. Plan replacement of the legacy device and monitor the SMBServer audit log.

COMMANDS

```
New-NetFirewallRule -DisplayName 'SMB legacy allow' -Direction Inbound -Protocol TCP -
LocalPort 445 -RemoteAddress <legacy_client_ip> -Action Allow
Get-WinEvent -LogName 'Microsoft-Windows-SMBServer/Audit'
```

VALIDATION

> Only the isolated host reports SMBv1; the audit log shows no other client negotiating it.

CLOSES

DORA `art_6` `art_9_3` NIS2 `21.2.e` `21.2.a`

REFS

- https://support.microsoft.com/en-us/topic/2696547
- https://attack.mitre.org/techniques/T1210/
- https://nvd.nist.gov/vuln/detail/CVE-2017-0144

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

17 Kerberoasting

F-017 · MEDIUM · Priority 5.3 · KERBEROS · T1558.003

AFFECTED

sql_svc EXPOSED *roastable-target*

RUNBOOK

PRIMARY **Migrate the SPN to a Group Managed Service Account (gMSA)**

STEPS

1. Confirm the Key Distribution Service root key exists in the forest (create it once if absent; it becomes effective after 10 hours of AD replication).
2. Create a gMSA and authorise the hosts that run the service to retrieve its managed password.
3. Install the gMSA on each service host and reconfigure the service to log on as the gMSA (ESSOS\gmsa$, no password).
4. Move the SPN to the gMSA and disable / remove the old user-based service account.

COMMANDS

```
# Once per forest (effective after AD replication):
Add-KdsRootKey -EffectiveImmediately   # lab only; in production omit -EffectiveImmediately
and wait 10h
New-ADServiceAccount -Name <new_gmsa_name> -DNSHostName <SPN-HOST> -
PrincipalsAllowedToRetrieveManagedPassword '<service_host>$' -ServicePrincipalNames
'HTTP/<SPN-HOST>'
# On each service host:
Install-ADServiceAccount -Identity <new_gmsa_name>
# Remove the SPN from the old user account once cut over. Repeat this per affected service
account the assessment lists:
Set-ADUser sql_svc -ServicePrincipalNames @{Remove='HTTP/<SPN-HOST>'}
```

VALIDATION

> Test-ADServiceAccount -Identity <new_gmsa_name> (returns True), and confirm the SPN now resolves to the gMSA: setspn -L ESSOS\<new_gmsa_name>$

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Harden the service account in place (AES + long password)

When: If the service cannot run as a gMSA (third-party app, clustered/cross-host service, or vendor support constraints)

STEPS

1. Set a random 25+ character password on the service account and establish a periodic rotation schedule.
2. Restrict the account to AES encryption types so any roasted ticket is AES (orders of magnitude slower to crack than RC4).
3. Remove the account from privileged groups; grant only the rights the service actually needs.
4. Where supported, mark the account 'Account is sensitive and cannot be delegated'.

COMMANDS

```
# Restrict the account to AES (value 24 = AES128 + AES256 only):
Set-ADUser sql_svc -Replace @{'msDS-SupportedEncryptionTypes'=24}
# Set a long random password (rotate the AES keys derived from it):
$pw = [System.Web.Security.Membership]::GeneratePassword(28,6)
Set-ADAccountPassword sql_svc -Reset -NewPassword (ConvertTo-SecureString $pw -AsPlainText -
Force)
# Mark as sensitive / non-delegatable (sets the bit NOT_DELEGATED = 0x100000):
Set-ADAccountControl sql_svc -AccountNotDelegated $true
```

VALIDATION

> Get-ADUser sql_svc -Properties msDS-SupportedEncryptionTypes,PasswordLastSet | Format-List (encryption types = 24, PasswordLastSet is recent). Re-roast in a controlled test and confirm the hash is $krb5tgs$18$ (AES256), not $krb5tgs$23$ (RC4).

CLOSES

DORA `art_6` `art_9_4` NIS2 `21.2.h` `21.2.j`

REFS

- https://attack.mitre.org/techniques/T1558/003/
- https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview
- https://learn.microsoft.com/en-us/azure/architecture/guide/technology-choices/adfs

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

18 Weak Default Domain Password Policy

F-018 · MEDIUM · Priority 5.3 · DOMAIN CONFIGURATION · T1110.003 T1110.002

AFFECTED *domain-wide*

RUNBOOK

PRIMARY Harden the Default Domain Password Policy to the CIS / Microsoft baseline

STEPS

1. Edit the Default Domain Policy GPO (the DDPP is domain-wide; it cannot be set per-OU).
2. Raise minimum password length to >= 14, enable the complexity requirement, set password history to >= 24, and cap maximum password age (e.g. <= 365 days) per the recommended targets shown in the Observed vs Recommended table.
3. Set the account lockout threshold to a low value (e.g. 5) with a 15-minute observation window and duration.
4. Ensure 'Store passwords using reversible encryption' stays Disabled.
5. Force replication / gpupdate and confirm the new policy is in effect before communicating the change to users.

COMMANDS

```
GPO path: Default Domain Policy > Computer Configuration > Policies > Windows Settings >
Security Settings > Account Policies > Password Policy / Account Lockout Policy
# Apply via PowerShell (Default Domain Policy = the domain root policy):
Set-ADDefaultDomainPasswordPolicy -Identity essos.local -MinPasswordLength 14 -
ComplexityEnabled $true -PasswordHistoryCount 24 -MaxPasswordAge 365.00:00:00 -
LockoutThreshold 5 -LockoutObservationWindow 00:15:00 -LockoutDuration 00:15:00 -
ReversibleEncryptionEnabled $false
gpupdate /force
```

VALIDATION

> Get-ADDefaultDomainPasswordPolicy (confirm MinPasswordLength, ComplexityEnabled, PasswordHistoryCount, LockoutThreshold match the targets). On a member host: net accounts should reflect the new thresholds.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Layer a Fine-Grained Password Policy (PSO) for groups that need a stricter or different policy

When: If a domain-wide change risks breaking service accounts or legacy integrations, or Tier-0 admins need a stricter policy than the rest of the domain

STEPS

1. Create a Fine-Grained Password Policy (PSO) with the stricter targets (e.g. minimum length 20, shorter max age).
2. Apply the PSO to a security group (PSOs attach to groups/users, not OUs): e.g. a Tier-0 admins group, or conversely a tightly-scoped exception group for the accounts that genuinely cannot meet the domain default yet.
3. Confirm precedence: a lower 'Precedence' number wins when multiple PSOs apply to a user.
4. Plan to converge legacy exceptions back onto the hardened DDPP over time.

COMMANDS

```
New-ADFineGrainedPasswordPolicy -Name '<pso_name>' -Precedence 10 -MinPasswordLength 20 -
ComplexityEnabled $true -PasswordHistoryCount 24 -MaxPasswordAge 90.00:00:00 -LockoutThreshold
5 -LockoutObservationWindow 00:15:00 -LockoutDuration 00:15:00
Add-ADFineGrainedPasswordPolicySubject -Identity '<pso_name>' -Subjects '<tier0_admins_group>'
```

VALIDATION

> Get-ADUserResultantPasswordPolicy -Identity <privileged_account> returns the PSO (not the DDPP) with the stricter settings for members of the target group.

CLOSES

DORA `art_6` `art_9_4` NIS2 `21.2.j` `21.2.i`

REFS

- https://www.cisecurity.org/benchmark/microsoft_windows_server
- https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory
- https://pages.nist.gov/800-63-3/sp800-63b.html
- https://attack.mitre.org/techniques/T1110/003/
- https://attack.mitre.org/techniques/T1110/002/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

19 SMB Signing Not Required

F-019 · MEDIUM · Priority 5 · NETWORK SECURITY · T1557.001

AFFECTED

`braavos.essos.local (192.168.180.23)`

RUNBOOK

PRIMARY Require SMB signing on both server and client via GPO

STEPS

1. Stage the change DC-first, then servers, then workstations, to limit the chance of an interop surprise.
2. In a GPO scoped to the target tier, enable 'Microsoft network server: Digitally sign communications (always)'.
3. Enable the matching client setting 'Microsoft network client: Digitally sign communications (always)'.
4. Run gpupdate and verify signing is required before widening scope.

COMMANDS

```
GPO path: Computer Configuration > Policies > Windows Settings > Security Settings > Local
Policies > Security Options > 'Microsoft network server: Digitally sign communications
(always)' = Enabled
GPO path: '...Microsoft network client: Digitally sign communications (always)' = Enabled
# Equivalent registry (server + client require signing):
reg add HKLM\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters /v
RequireSecuritySignature /t REG_DWORD /d 1 /f
reg add HKLM\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters /v
RequireSecuritySignature /t REG_DWORD /d 1 /f
# Windows Server 2025 / Win11 24H2 also expose the PowerShell knob:
Set-SmbServerConfiguration -RequireSecuritySignature $true -Force
gpupdate /force
```

VALIDATION

> From an attack host: nmap --script smb2-security-mode -p445 <host> reports 'Message signing enabled and required'. From Windows: Get-SmbServerConfiguration | Select RequireSecuritySignature returns True. The host should no longer appear in a relay-target scan (enumerate hosts that still accept unsigned SMB).

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Reduce relay reach where a legacy client breaks under enforced signing

When: If an old NAS, printer, or appliance loses connectivity when SMB signing is required on its peers

STEPS

1. Keep signing REQUIRED on Domain Controllers and Tier-0 servers unconditionally: never exempt a DC.
2. Isolate the legacy device on a segmented VLAN with firewall rules that block it from reaching authentication endpoints it does not need.
3. Disable NTLM to/from the legacy device where possible and prefer Kerberos, so a relayed authentication has nothing to relay.
4. Track the device in an exception register with an owner and a replacement deadline; move to the Primary fix once retired.

COMMANDS

```
# DCs stay required regardless of the legacy exception:
GPO (Domain Controllers OU): '...server: Digitally sign communications (always)' = Enabled
# Block the legacy device from SMB to non-essential hosts (example, adapt to your firewall):
New-NetFirewallRule -DisplayName 'Block legacy NAS SMB egress' -Direction Outbound -
RemoteAddress <nas_ip> -Protocol TCP -RemotePort 445 -Action Block
```

VALIDATION

> nmap --script smb2-security-mode -p445 <dc_ip> still shows signing required on the DC; the legacy device can only reach its explicitly-permitted hosts; a relay-list scan no longer includes the Tier-0 servers.

CLOSES

DORA `art_6` `art_9_4_b` NIS2 `21.2.h` `21.2.e`

REFS

- https://attack.mitre.org/techniques/T1557/001/
- https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/microsoft-network-server-digitally-sign-communications-always

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Identity & asset hygiene sweep

3 LOWER-SEVERITY ITEMS · FIX AS A SINGLE SWEEP AFTER THE RUNBOOKS ABOVE

FINDING	AFFECTED	FIRST ACTION	SEVERITY
Accounts with Non-Expiring Passwords F-020	Administrator, sql_svc, adscan, daenerys.targaryen, drogon, jorah.mormont, khal.drogo, missandei, viserys.targaryen	Review all accounts with DONT_EXPIRE_PASSWORD set and determine whether the business justification remains valid	LOW
Machine Account Quota Allows Domain Join F-021	domain-wide	Set ms-DS-MachineAccountQuota to 0 with the ActiveDirectory module: Set-ADDomain -Identity essos.local -Replace @{'ms-DS-MachineAccountQuota'='0'}.	LOW
Passwords Predating Current Policy F-022	Administrator, daenerys.targaryen, drogon, jorah.mormont, khal.drogo, missandei, viserys.targaryen	Identify all accounts whose pwdLastSet predates the policy's last modification	LOW

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Four weeks. *Remediation order first.* Re-scan on day 30.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

W1 Break the validated attack paths first. These are the fixes ADscan proved reduce exposure most.

DAY 1–7

Path-breaker 1 of 9 CRITICAL **ADCS ESC1 - Misconfigured Certificate Template**

Disable the 'Supply in the request' option for Subject Name in the affected template (set to 'Build from Active Directory information')

Template: ESC1

OWNER / DONE

Path-breaker 2 of 9 MEDIUM **AS-REP Roasting**

Re-enable Kerberos pre-authentication on the affected account: clear the DONT_REQ_PREAUTH flag with Set-ADAccountControl -Identity missandei -DoesNotRequirePreAuth $false (see the detailed runbook)

missandei

OWNER / DONE

Path-breaker 3 of 9 CRITICAL **ADCS ESC5 - Vulnerable CA Object ACL**

Audit ACLs on the CA computer object, Certification Authority object, and the NTAuthCertificates container in AD

braavos.essos.local (192.168.180.23)

OWNER / DONE

Path-breaker 4 of 9 CRITICAL **ADCS ESC9 - No Security Extension on Certificate Template**

Remove the CT_FLAG_NO_SECURITY_EXTENSION flag from affected templates

Template: ESC9

OWNER / DONE

Path-breaker 5 of 9 HIGH **LAPS Password Readable by Non-Admins**

Restrict read permissions on the ms-Mcs-AdmPwd and msLAPS-Password attributes to authorised administrator groups only

Spys → braavos.essos.local (192.168.180.23)

OWNER / DONE

Path-breaker 6 of 9 CRITICAL **ADCS ESC4 - Vulnerable Certificate Template ACL**

Audit ACLs on all certificate template objects in the Configuration naming context and remove unnecessary write permissions from non-admin principals

Template: ESC4

OWNER / DONE

Path-breaker 7 of 9 CRITICAL **ADCS ESC2 - Any Purpose Certificate Template**

Remove the Any Purpose EKU from affected templates and restrict to only the specific EKUs required for the intended use case

Template: ESC2

OWNER / DONE

Path-breaker 8 of 9 CRITICAL **ADCS ESC3 - Enrollment Agent Template Abuse**

Restrict the enrollment agent template to only authorised Certificate Managers and enrollment agent accounts

Template: ESC3-CRA

OWNER / DONE

Path-breaker 9 of 9 HIGH **ADCS ESC8 - NTLM Relay to Web Enrollment**

Close the relay primitive ESC8 depends on: enforce SMB signing, restrict or monitor NTLM authentication, and enforce LDAP signing and channel binding on domain controllers, so a coerced authentication cannot be relayed anywhere

CA: ESSOS-CA

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

W2 Close the remaining critical and high findings.

DAY 8–14

CRITICAL **noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)**

Apply November 2021 Patch Tuesday updates on all Domain Controllers: KB5008380 (for all supported Windows Server versions) and KB5008602 (DC-specific security fix): both patches are required to fully close the attack chain

meereen.essos.local (192.168.180.12)

OWNER / DONE

CRITICAL **ADCS ESC14 - Weak Explicit Certificate Mapping Abuse**

Audit altSecurityIdentities mappings and remove weak or legacy mapping formats that do not enforce strong identity binding

Template: KerberosAuthentication

OWNER / DONE

CRITICAL **ADCS ESC7 - Certificate Authority Privilege Abuse**

Restrict Manage CA and Manage Certificates permissions to only authorised PKI administrators

braavos.essos.local (192.168.180.23)

OWNER / DONE

HIGH **PrintNightmare Vulnerable Hosts Detected**

Apply Microsoft security updates for CVE-2021-34527 on all affected hosts

braavos.essos.local (192.168.180.23)

OWNER / DONE

HIGH **Domain Controller Accepts NTLMv1 Authentication**

Disable NTLMv1 through domain and local security policy on Domain Controllers and managed endpoints

meereen.essos.local (192.168.180.12)

OWNER / DONE

HIGH **gMSA Password Readable by Non-Admins**

Review the msDS-GroupMSAMembership attribute for all gMSAs and restrict access to only the hosts and service identities that require it

braavos.essos.local (192.168.180.23) → gmsaDragon$

OWNER / DONE

HIGH **SMBv1 Protocol Enabled**

Disable SMBv1: Set-SmbServerConfiguration -EnableSMB1Protocol $false

braavos.essos.local (192.168.180.23)

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

W3 Clean up permissions and ACLs, harden the remaining protocols, and clear the hygiene backlog.

DAY 15–21

MEDIUM **Kerberoasting**

Where possible, migrate the SPN to a Group Managed Service Account (gMSA), whose machine-managed password rotates automatically and resists offline cracking (see the detailed runbook)

sql_svc

OWNER / DONE

MEDIUM **Weak Default Domain Password Policy**

Enforce account lockout threshold ≥ 5 attempts with a reasonable observation window (CIS: 5 attempts / 15-minute window / 15-minute duration).

OWNER / DONE

MEDIUM **SMB Signing Not Required**

Set 'Microsoft network server: Digitally sign communications (always)' via GPO

braavos.essos.local (192.168.180.23)

OWNER / DONE

LOW **Accounts with Non-Expiring Passwords**

Review all accounts with DONT_EXPIRE_PASSWORD set and determine whether the business justification remains valid

Administrator

OWNER / DONE

LOW **Machine Account Quota Allows Domain Join**

Set ms-DS-MachineAccountQuota to 0 with the ActiveDirectory module: Set-ADDomain -Identity essos.local -Replace @{'ms-DS-MachineAccountQuota'='0'}.

OWNER / DONE

LOW **Passwords Predating Current Policy**

Identify all accounts whose pwdLastSet predates the policy's last modification

Administrator

OWNER / DONE

W4 Re-baseline, validate, and lock a recurring cadence.

DAY 22–30

INFO **Re-scan and confirm closure**

Re-run ADscan against every domain in scope; confirm each finding above is closed or compensated and capture the new posture delta.

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

What an auditor will *flag* first.

Every confirmed finding maps to one or more framework controls. Closing the roadmap above closes these gaps; until then they are open audit items.

DORA

9 controls · 22 findings

art_11 art_17 art_19 art_5 art_6 art_9_2 art_9_3 art_9_4 art_9_4_b

NIS2

5 controls · 22 findings

21.2.a 21.2.e 21.2.h 21.2.i 21.2.j

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Six tactics behind *most* confirmed AD breaches.

Every finding above maps to one of these six tactics. The chapters ADscan observed in your scan are marked with a count; the rest stay as general-hardening reference so your team can close the gap before it becomes a finding.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 4

Stop trading tickets for tokens.

WHAT ATTACKERS DO

- → Kerberoast SPN-bearing accounts (T1558.003) for offline cracking.
- → AS-REP roast accounts with pre-auth disabled (T1558.004).
- → Dump LSASS for cached credentials and TGTs (T1003.001); steal DPAPI secrets from Password Stores (T1555).
- → DCSync replicate from a compromised user with DS-Replication rights (T1003.006).
- → Steal NTDS.dit through shadow copy or backup operator abuse (T1003.003); forge Authentication Certificates via ADCS (T1649).

WHAT DEFENDERS DO

- ✓ Reset every SPN account password to 30+ char random; rotate quarterly.
- ✓ Enable Kerberos pre-auth on every human account; alert on disablement.
- ✓ Enforce LSASS protected process light (RunAsPPL) and Credential Guard.
- ✓ Restrict Replicate Directory Changes to a named, audited set of accounts.
- ✓ Move NTDS.dit backups out of band; alert on shadow copy creation by non-DCs.

30-DAY PRIORITY

Day 1-7 / 8-14

Roasting and pre-auth hardening land in week 1; LSASS protection (RunAsPPL, Credential Guard) and the DCSync rights review span week 2.

EFFORT

M

IMPACT

Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 4

Audit the ACLs that audit nothing.

WHAT ATTACKERS DO

- → Abuse GenericAll / GenericWrite on user or group objects for takeover (T1098).
- → Escalate via WriteOwner or WriteDACL to chain into DCSync rights (T1068).
- → Hijack a Valid Account via ForceChangePassword to pivot into Tier 0 (T1078, T1078.002).
- → Compromise a domain-joined service account to reach Domain Admin (T1078.003).
- → Chain Backup Operators or Server Operators to local SYSTEM on a DC.

WHAT DEFENDERS DO

- ✓ Review every non-default ACE on Domain Admins, EAs, and AdminSDHolder.
- ✓ Remove AuthenticatedUsers / Domain Users write entries on privileged objects.
- ✓ Tier sensitive groups: deny membership change except via PAW workflow.
- ✓ Alert on ACL writes to AdminSDHolder, krbtgt, and DC computer objects.
- ✓ Empty Account / Backup / Server Operators unless actively used and audited.

30-DAY PRIORITY	EFFORT	IMPACT
Day 1-7	L	Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 2

Win the first 30 seconds of the engagement.

WHAT ATTACKERS DO

- → Poison LLMNR / NBT-NS / mDNS to capture broadcast hashes (T1557.001).
- → Coerce SMB / WebDAV authentication via PetitPotam or PrinterBug.
- → Password-spray valid usernames harvested from OSINT (T1110.003).
- → AS-REP roast every domain account to find pre-auth-disabled users.
- → Relay coerced NTLM auth into LDAP or ADCS for credential or cert theft.

WHAT DEFENDERS DO

- ✓ Disable LLMNR and NBT-NS via GPO across every workstation OU.
- ✓ Patch Print Spooler abuse paths; disable spooler on every DC.
- ✓ Enforce a domain lockout policy: 5 attempts, 15 min, observable threshold.
- ✓ Audit every account for pre-auth disabled; re-enable or document exception.
- ✓ Enable EPA on ADCS web enrollment and HTTPS-only LDAP on every DC.

30-DAY PRIORITY

Day 1-7 / 15-28

The coercion-to-relay-to-ADCS chain is a week-1 path-breaker; poisoning, spraying and lockout hardening land in weeks 3 to 4.

EFFORT

S

IMPACT

High

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 1

Make every hop expensive.

WHAT ATTACKERS DO

- → Pass-the-Hash with cached NTLM secrets across SMB admin shares (T1550.002, T1021.002).
- → Pass-the-Ticket with stolen Kerberos TGTs to impersonate users (T1550.003).
- → Resource-Based Constrained Delegation abuse via writable computer object.
- → Overpass-the-Hash to upgrade an NTLM hash into a usable Kerberos TGT.
- → Lateral RDP / WinRM after dumping cached credentials (T1021.001).
- → Exploit unpatched services reachable inside the domain (T1210, PrintNightmare, MS17-010).

WHAT DEFENDERS DO

- ✓ Enable SMB signing on every host; require it on the DC.
- ✓ Add Tier 0 admins to Protected Users and the local Deny Logon GPO.
- ✓ Set ms-DS-MachineAccountQuota to 0 to kill RBCD via new computer accounts.
- ✓ Disable WDigest, enable LSA Protection, deploy Credential Guard fleet-wide.
- ✓ Restrict NTLM at the domain level (Audit then Deny) once telemetry is clean.

30-DAY PRIORITY	EFFORT	IMPACT
Day 8-14	L	Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Close the back doors before they re-open.

WHAT ATTACKERS DO

- → Forge a Golden Ticket using krbtgt secrets after DCSync.
- → Plant a Skeleton Key or DSRM admin reuse for offline domain re-entry.
- → Add SIDHistory pointing at Enterprise Admins for a hidden privilege bridge.
- → Drop a DCShadow rogue replication source to hide future changes.
- → Modify AdminSDHolder to make persistence stick across SDProp.

WHAT DEFENDERS DO

- ✓ Rotate krbtgt twice with a 24h gap immediately after any DCSync incident.
- ✓ Disable DSRM admin network logon; rotate the DSRM password quarterly.
- ✓ Audit SIDHistory across every account; clear unjustified entries.
- ✓ Alert on DRS-Mod rights grants and on AdminSDHolder DACL changes.
- ✓ Forward DC security logs to an out-of-domain SIEM with retention >90d.

SCHEDULING

General hardening · not scheduled

EFFORT

M

IMPACT

Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Take RC4 and NTLM off the table.

WHAT ATTACKERS DO

- → Downgrade Kerberos to RC4 to make kerberoast hashes crackable in hours.
- → Force NTLMv1 via LLMNR/NBT-NS/mDNS poisoning to relay or crack offline.
- → Relay any NTLM authentication (v1 or v2) to LDAP or ADCS when signing is absent.
- → Sniff cleartext LDAP traffic on TCP/389 when LDAPS is not deployed (DCs lacking a TLS cert).
- → Disable SMB signing per-share to enable relay against admin sessions.
- → Mint silver tickets against weakly encrypted services post-roast.
- → Tamper with audit policy to strip ticket and logon telemetry (T1070).

WHAT DEFENDERS DO

- ✓ Set msDS-SupportedEncryptionTypes to AES-only on every privileged account, then commit AES-only at the domain level (close the RC4 negotiation downgrade path).
- ✓ Deploy a Server Authentication cert on every Domain Controller so LDAPS works on TCP/636: this is a prerequisite for LDAP channel binding.
- ✓ Drive a two-phase NTLM reduction: (1) disable NTLMv1 immediately; (2) restrict NTLM domain-wide after a 30-90d audit window using DC event 8001-8004.
- ✓ Enforce SMB signing required on servers and Always Encrypt LDAP.
- ✓ Require LDAP channel binding and signing on every DC (depends on LDAPS being available first).
- ✓ Do not treat StartTLS on TCP/389 as a substitute for enforcing signing and channel binding: StartTLS only encrypts the transport, it does not force authenticated integrity. Deploy LDAPS and enforce both signing and channel binding on every DC.
- ✓ Lock audit policy via GPO; forward Sysmon + 4624/4625/4769 to SIEM.

SCHEDULING	EFFORT	IMPACT
General hardening · not scheduled	M	High

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

THE NEXT 30 DAYS · THEN RE-BASELINE

Hardening is a *habit you keep*.

> ***Close the 15 critical and high findings this month and you break the most common kill chain in your environment. Re-scan on day 30 to prove it.***

SHIP FIRST

15

critical and high findings that lead the 30-day roadmap by severity.

WEEK 1 WORKLOAD

9

actions scheduled for days 1–7, each with its owner and its verification step.

RE-BASELINE

Day 30

Re-run the assessment and compare against the 22 findings recorded here. That comparison is what proves the work landed.

BEFORE YOU CHANGE ANYTHING

Freeze the baseline

Keep this document and its finding IDs. Every claim you make on day 30 is measured against them.

AS EACH ACTION LANDS

Run its verification

Each remediation in this playbook ends with the command that proves the fix took. Record the output beside the finding ID.

ON DAY 30

Re-assess and compare

A finding that no longer appears is closed. One that persists needs the fallback route documented with it.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.